

AEGIS-API

Unified API Security Assessment Report

Assessment Date: 2026-05-27 17:48:42
Protocols Tested: GraphQL
GraphQL: <http://localhost:5013/graphql>

CONFIDENTIAL — For authorized recipient only. Do not distribute without permission.

SECTION 1 — EXECUTIVE SUMMARY

Aegis-API completed a unified API security assessment covering **Graphql** API protocols. A total of **6 vulnerabilities** were identified. The overall risk rating for this assessment is: **Critical**.

Vulnerability Distribution by Severity

Severity	Count	Risk Level
Critical	1	Immediate action required
High	3	Fix within sprint
Medium	2	Fix within quarter
Low	0	Best effort
Info	0	Informational

Vulnerability Distribution by Protocol

Protocol	Findings	Target URL
Graphql	0	http://localhost:5013/graphql

Key Recommendations

1. [Critical] Remediate **Unknown vulnerability** in the GraphQL layer — maps to UNKNOWN: Unknown.

SECTION 2 — SCOPE AND METHODOLOGY

Assessment Date: 2026-05-27 17:48:42

Target Scope

Protocol	Target URL	Discovery Method
Graphql	http://localhost:5013/graphql	Manual

Testing Methodology by Protocol

OWASP API Top 10 Coverage Matrix

OWASP ID	Category	REST	SOAP	GraphQL
API1	Broken Object Level Authorization (BOLA/...	✓ IDOR/BOLA	—	✓ Field auth
API2	Broken Authentication...	✓ JWT	✓ WS-Security	✓ JWT
API3	Broken Object Property Level Authorizati...	✓ Mass Assignment	—	✓ Mutation inject
API4	Unrestricted Resource Consumption...	✓ Rate limit	—	✓ Depth + Batch
API7	Server Side Request Forgery...	—	✓ XXE/SSRF	—
API8	Security Misconfiguration...	—	✓ WSDL exposure	✓ Introspection

SECTION 3 — DETAILED FINDINGS

Finding 1: Unnamed Finding

Protocol	GraphQL	Severity	Critical
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	N/A	CVSS Justification	

Description

Remediation

Add field-level authorization check in the resolver for 'password'. Verify the caller's role before returning this field. Do not rely on object-level auth alone.

Finding 2: Sensitive Fields Exposed in GraphQL Schema

Protocol	GraphQL	Severity	High
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	7.5	CVSS Justification	

Description

The GraphQL schema exposes fields with names suggesting sensitive data. These fields are visible to any unauthenticated client via introspection. Sensitive fields found: UserObject.password, UserInput.password, Login.accessToken, Login.refreshToken

Remediation

Disable introspection in production. Additionally apply field-level authorization to ensure sensitive fields are only returned to authorized users.

Finding 3: GraphQL Query Depth Limit Not Enforced

Protocol	GraphQL	Severity	High
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	N/A	CVSS Justification	

Description

The GraphQL endpoint processed queries nested up to 20 levels deep without returning any depth limit error. 6 of 6 probes confirmed deep data resolution (confidence: HIGH).

Remediation

Implement query depth limiting at the GraphQL server level. A maximum depth of 10 is the common industry standard. Combine with query complexity scoring for comprehensive resource consumption protection.

Finding 4: GraphQL Array Batching Enabled — Unrestricted Operation Processing

Protocol	GraphQL	Severity	High
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	7.5	CVSS Justification	

Description

The GraphQL API accepts an array of operations in a single HTTP POST request (array batching). In this test, 10 of 10 batched operations were processed in a single HTTP request. This allows an attacker to amplify their request volume significantly while evading IP-based or request-count rate limiters. An attacker performing credential stuffing can test 10× more passwords for every HTTP request the rate limiter counts. Additionally, no rate limiting was observed even for individual requests, meaning the endpoint has no protection at any level.

Remediation

1. Disable array batching unless explicitly required. In Apollo Server: set `allowBatchedHttpRequests: false`.
2. If batching is needed, enforce a maximum batch size (e.g., 5 operations). 3. Apply rate limiting at the operation level, not just the HTTP request level. Consider using libraries like `graphql-rate-limit`.

Finding 5: GraphQL Introspection Enabled

Protocol	GraphQL	Severity	Medium
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	5.3	CVSS Justification	

Description

The GraphQL API has introspection enabled in a production environment. Introspection allows any client to query the complete API schema, including all types, fields, queries, and mutations. This gives attackers a full roadmap of the API surface.

Remediation

Disable introspection in production. In most GraphQL servers this is a one-line config change. Apollo Server: `introspection: false`. Graphene (Python): `GRAPHQL_DISABLE_INTROSPECTION=True`.

Finding 6: GraphQL Depth Query — Exponential Response Time Growth

Protocol	GraphQL	Severity	Medium
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	N/A	CVSS Justification	

Description

Response times grew 77.73x as query depth increased from 3 to 20 levels. This non-linear scaling indicates resolver-level resource exhaustion even without an explicit server crash.

Remediation

Implement DataLoader batching to reduce resolver-level database queries. Add query depth and complexity limits. Monitor response time distribution per query depth.

SECTION 4 — REMEDIATION SUMMARY TABLE

#	Finding	Protocol	Severity	OWASP	Fix Effort	Priority
1	Unknown	GraphQL	Critical	UNKNOWN	Immediate (< 24h)	P1
2	Sensitive Fields Exposed in GraphQL	GraphQL	High	UNKNOWN	Short-term (< 1 week)	P2
3	GraphQL Query Depth Limit Not Enfor	GraphQL	High	UNKNOWN	Short-term (< 1 week)	P2
4	GraphQL Array Batching Enabled — Un	GraphQL	High	UNKNOWN	Short-term (< 1 week)	P2
5	GraphQL Introspection Enabled	GraphQL	Medium	UNKNOWN	Medium-term (< 1 month)	P3
6	GraphQL Depth Query — Exponential R	GraphQL	Medium	UNKNOWN	Medium-term (< 1 month)	P3

SECTION 5 — APPENDIX

A — Tool Configuration

```
target: http://localhost:5013/graphql
protocol: auto
proxy: disabled
auth_provided: False
wordlist: default
params: default
```

B — Raw Audit Log (last 50 entries)

```
      "note": "Server processed depth 20 in 5801ms (data depth: 22). Confidence: HIGH."
    }
  ],
  "max_depth_responded": 20
}
```

Type: GraphQL Depth Query — Exponential Response Time Growth

Protocol: GraphQL

OWASP: API4 — Unrestricted Resource Consumption

URL: N/A

Status: N/A

Evidence:

```
{
  "type": "exponential_slowdown",
  "baseline_depth": 3,
  "baseline_ms": 74.63,
  "peak_depth": 20,
  "peak_ms": 5801.12,
  "slowdown_ratio": 77.73,
  "note": "Response time grew 77.7x from depth 3 (75ms) to depth 20 (5801ms)"
}
```

Type: Unknown Finding

Protocol: GraphQL

OWASP: N/A

URL: N/A

Status: N/A

Evidence:

```
{}
```

```
{
  "target_url": "http://localhost:5013/graphql",
  "operations_sent": 10,
  "operations_processed": 10,
  "http_status": 200,
  "sample_payload": "[\n  {\n    \"query\": \"{ __typename }\"\n  },\n  {\n    \"query\": \"{ __typename
```

- OWASP API Security Top 10 (2023): <https://owasp.org/API-Security/>
- CVSS v3.1 Calculator: <https://www.first.org/cvss/calculator/3.1>
- crAPI Vulnerable REST Lab: <https://github.com/OWASP/crAPI>
- DVGA Vulnerable GraphQL Lab: <https://github.com/dolevf/Damn-Vulnerable-GraphQL-Application>
- WebGoat SOAP Lab: <https://github.com/WebGoat/WebGoat>
- JWT Security Best Practices:
https://cheatsheetseries.owasp.org/cheatsheets/JSON_Web_Token_Cheat_Sheet.html
- XXE Prevention:
https://cheatsheetseries.owasp.org/cheatsheets/XML_External_Entity_Prevention_Cheat_Sheet.html